

UNIVERSIDAD
COMPLUTENSE
MADRID

Sprint 4

Anexo C: Comunidad y seguridad

Ética de Datos e IA

Yao Chen

Jiahao Cheng

Jorge Hernández Palop

Alicia Pereda Bordejé

Jiayi Wang

08/11/2026

1 Introducción

Que un proyecto sea abierto no depende solo de que el código esté publicado. También depende de que cualquiera pueda entender cómo se licencia, cómo se participa y qué ocurre cuando alguien incumple las normas. GitHub tiene un perfil de comunidad que mide justo eso [1], y nosotros hemos querido cubrirlo desde el principio. De todos los *checks* disponibles hemos elegido el Código de Conducta, la política de seguridad y el documento de contribución.

2 Código de Conducta

Para el Código de Conducta partimos del *Contributor Covenant* 3.0 [2]. Es el estándar que más se usa en comunidades de software libre y GitHub ofrece una plantilla basada en él [3]. Podríamos haber escrito uno propio, pero nos habría costado más tiempo y probablemente habría dejado lagunas o reglas ambiguas. Tampoco nos convencía copiar el de otro proyecto, porque contendría datos demasiados específicos del proyecto en cuestión.

Del texto normativo hemos copiado el compromiso, la conducta esperada, los comportamientos no permitidos, la escala de reparación, el alcance y la atribución, y solo hemos tocado lo que el propio estándar deja abierto. Lo que sí hemos adaptado es el canal de reporte y el reparto de responsabilidades, el equipo de moderación y la abstención cuando el aviso afecta a uno de sus miembros, los plazos de acuse, valoración y resolución, el mecanismo de apelación, el alcance concreto (GitHub, wiki, correo, redes y eventos), dos reglas propias del proyecto (citar fuentes y respetar la guía de uso de marca) y la traducción al español. No hemos reescrito los valores ni la escala de sanciones.

3 Política de seguridad

Para la política de seguridad nos fijamos en la de *Ruby on Rails* [4]. Mantenemos la estructura de Rails: versiones soportadas, reporte privado, proceso de divulgación, recepción de avisos y crédito. Lo que cambia es el contenido, que hemos adaptado a TTC.

Como todavía no tenemos releases, `main` es la única rama que recibe correcciones y no hay backports. Para reportar vulnerabilidades usamos GitHub Private Vulnerability Reporting y el correo del proyecto. Los plazos que nos hemos puesto son un acuse en 3 días laborables, una primera valoración en 7, actualizaciones cada 10 y un embargo de 90 días naturales, salvo que acordemos otra cosa. En el alcance incluimos código, datos, credenciales, *prompt injection*, envenenamiento de datos y fuga de claves. Fuera dejamos la exactitud de la información, el copyright y las marcas (que van al canal de reclamaciones) y los ataques a terceros. También hemos añadido una cláusula de investigación de buena fe y hemos dejado claro que no pagamos recompensas.

Elegimos Rails porque es un proyecto maduro, separa el reporte privado de la divulgación y deja claro qué está y qué no está en alcance. Un `SECURITY.md` que solo diga “escribe a este correo” no evita que los investigadores abran issues públicos ni reduce el riesgo de que un fallo se haga público antes de que exista una corrección.

Además de los documentos, hemos activado las protecciones de seguridad de GitHub [5]. Tenemos el reporte privado de vulnerabilidades, el *secret scanning* para avisar si se sube un token o una credencial, las alertas de *Dependabot* y las actualizaciones de seguridad, y las alertas de malware y de cadena de suministro a través del grafo de dependencias. Estas medidas no sustituyen la revisión humana: cada alerta se mira y se documenta, y si aparece un secreto se revoca aunque la alerta llegue después de la subida.

4 Contribuir al proyecto

Para el *check* de *Contributing* adaptamos el proceso de *Graphify*, un proyecto de código abierto que convierte repositorios y documentos en un grafo de conocimiento consultable [6]. Nos interesa porque su guía está organizada alrededor de las mismas invariantes que TTC: procedencia, determinismo, actuali-

zaciones incrementales seguras y separación entre hecho extraído e inferencia. No es una guía de "haz un fork y abre un PR", sino que explica qué tiene que preservar un cambio para no corromper el grafo.

La estructura y los principios los hemos copiado: antes de empezar, qué valoramos, arquitectura, puesta en marcha, cómo hacer un cambio, tests, integridad de datos, seguridad, mensajes de commit, pull requests, trabajo con agentes de IA, reporte de issues, revisión y artefactos generados. Lo hemos adaptado a TTC: la arquitectura y el pipeline del Sprint 2, las reglas de integridad de datos para fuentes, grafo y cachés, el flujo de documentación en Typst y la compilación con `build.sh`, el DCO en lugar del CLA para no exigir cesión de derechos y mantener AGPL-3.0, la declaración de IA con `Co-Authored-By` y enlace público al log, y el canal de ayuda (GitHub Discussions e issues, sin Discord).

Al final decidimos no usar plantillas de issue separadas. El propio `CONTRIBUTING.md` describe qué debe incluir un bug, una propuesta o una contribución de datos o modelo, y así no duplicamos campos y mantenemos una única fuente de verdad. Sí mantenemos una plantilla de pull request, porque el PR es el punto donde se comprueban las invariantes y las listas de verificación.

5 Licencia, mantenimiento y trazabilidad

El código de TTC se distribuye bajo AGPL-3.0. El Código de Conducta es un documento independiente y se distribuye bajo CC BY-SA 4.0 [7], como exige el propio *Contributor Covenant* [2]. La licencia del software no se aplica a la conducta de las personas, y el Código de Conducta no cambia las libertades del software.

El Código se revisa anualmente o tras un incidente grave. Si cambia el equipo de moderación o el canal de reporte, se actualiza el documento y se avisa en el repositorio. Los informes se conservan como máximo doce meses y se publica un resumen anual anonimizado. El documento completo está en CODE_OF_CONDUCT.md, y la versión adaptada mantiene la atribución a *Contributor Covenant* 3.0 y su licencia CC BY-SA 4.0.

Bibliografía

[1] GitHub, «About community profiles for public repositories». Accedido: 8 de noviembre de 2026. [En línea]. Disponible en: https://docs.github.com/en/communities/setting-up-your-project-for-healthy--contributions/about-community-profiles-for-public-repositories

[2] Organization for Ethical Source, «Contributor Covenant, version 3.0». Accedido: 8 de noviembre de 2026. [En línea]. Disponible en: https://www.contributor-covenant.org/version/3/0/

[3] GitHub, «Adding a code of conduct to your project». Accedido: 8 de noviembre de 2026. [En línea]. Disponible en: https://docs.github.com/en/communities/setting-up-your-project-for-healthy--contributions/adding-a-code-of-conduct-to-your-project

[4] Rails Foundation, «Security Policy». Accedido: 8 de noviembre de 2026. [En línea]. Disponible en: https://rubyonrails.org/security

[5] GitHub, «GitHub security features». Accedido: 8 de noviembre de 2026. [En línea]. Disponible en: https://docs.github.com/en/code-security/getting-started/github-security-features

[6] Graphify Labs, «Contributing to Graphify». Accedido: 8 de noviembre de 2026. [En línea]. Disponible en: https://github.com/Graphify-Labs/graphify/blob/v8/CONTRIBUTING.md

[7] Creative Commons, «Attribution-ShareAlike 4.0 International (CC BY-SA 4.0)». Accedido: 8 de noviembre de 2026. [En línea]. Disponible en: https://creativecommons.org/licenses/by-sa/4.0/